

Critical Intelligence Briefing: CVE-2026-52778

CRITICAL SEVERITY

Target System	 YesWiki Open-Source Collaborative Platform 
Vulnerability Classes	 Remote Code Execution (RCE) +  Regular Expression Denial of Service (ReDoS)
Date of Briefing	Immediate

Immediate Triage and Severity Metrics

9.8
CRITICAL

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

- ☒ Network Vector:
YES
- ☒ Authentication
Required: **NO**
- ☒ Complexity:
LOW
- ☒ User Interaction:
NONE

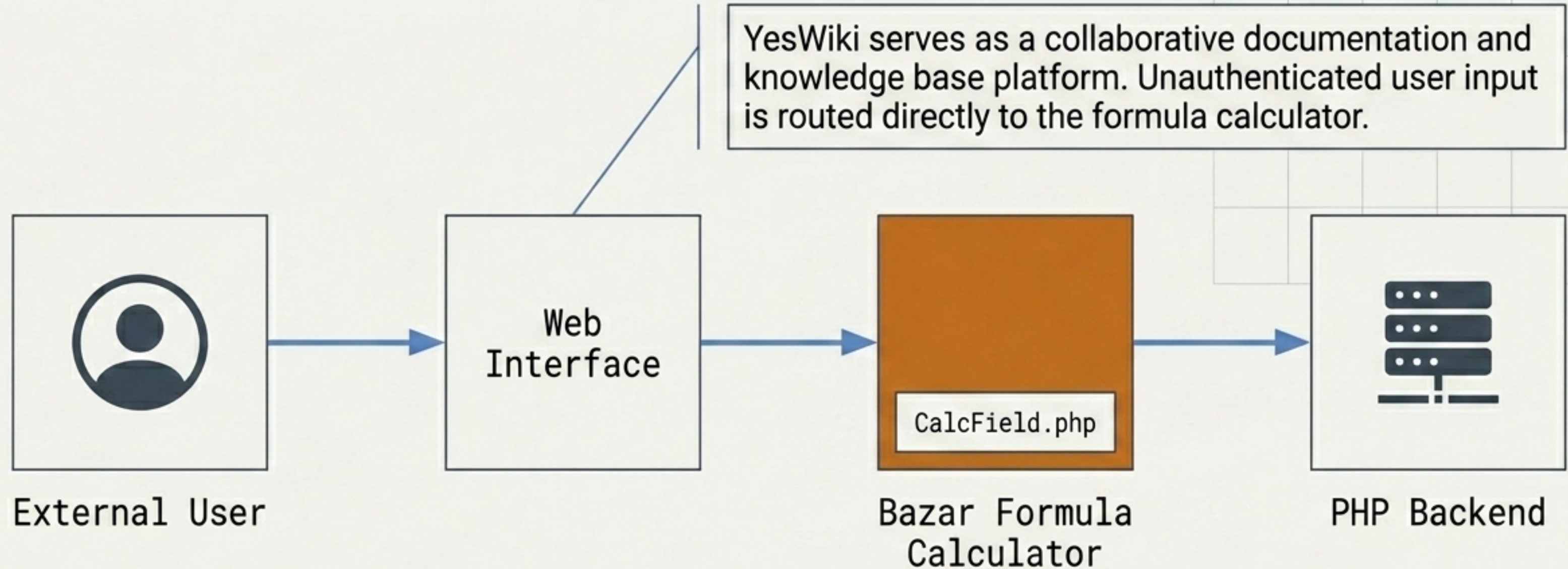


YesWiki
(Versions < 4.6.6)

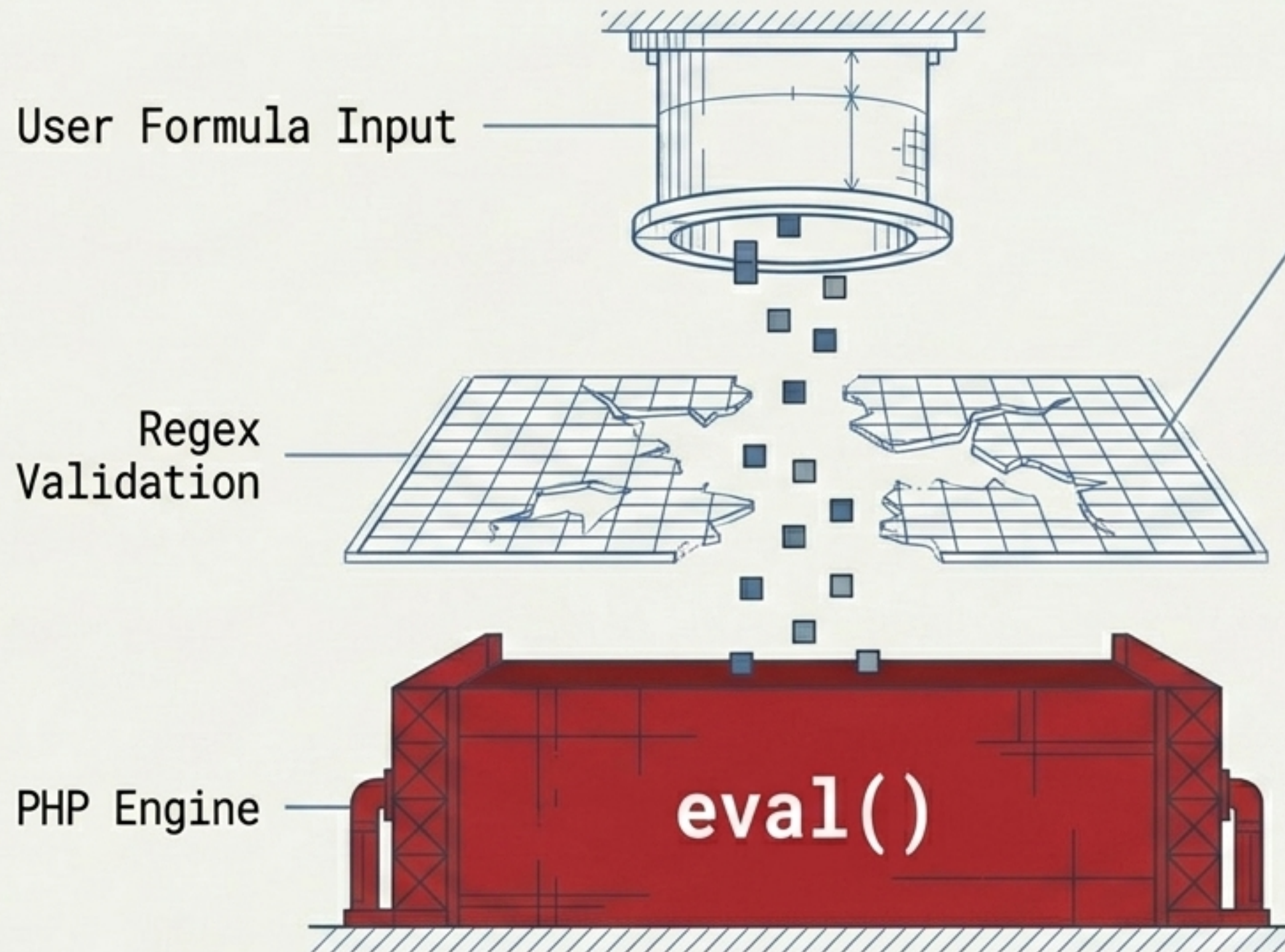
Vulnerable Component

Bazar Formula Calculator
(CalcField.php)

Architecture and the Structural Weak Point



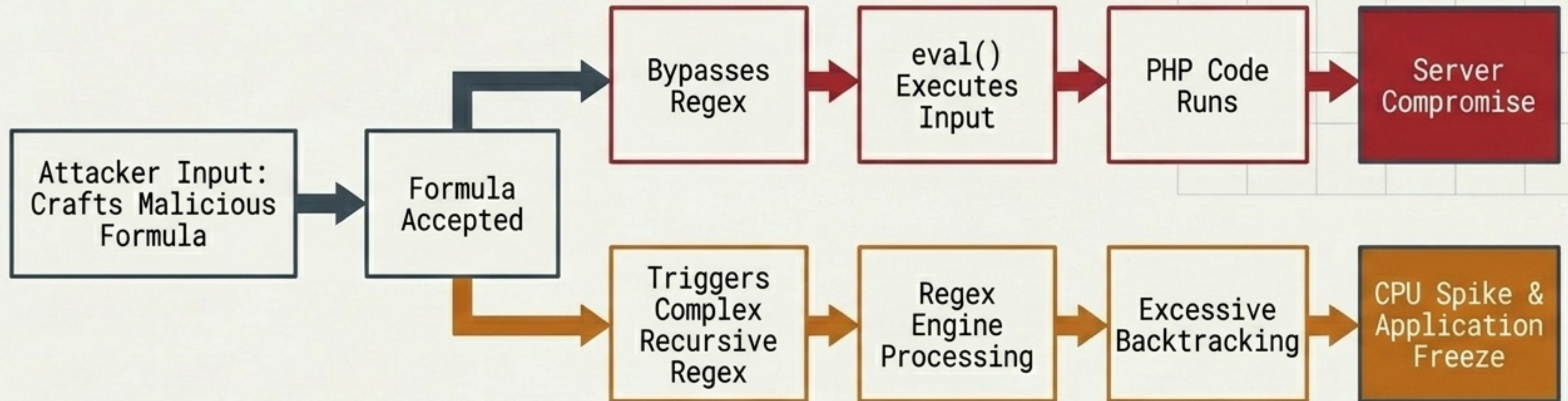
The Code Execution Trapdoor



The application relies entirely on regex filtering to sanitize input. Because this validation is incomplete, malicious strings bypass the filter and execute directly inside PHP's `eval()` function.

CWE-94: Improper Control of Generation of Code

Branching Exploitation Pathways

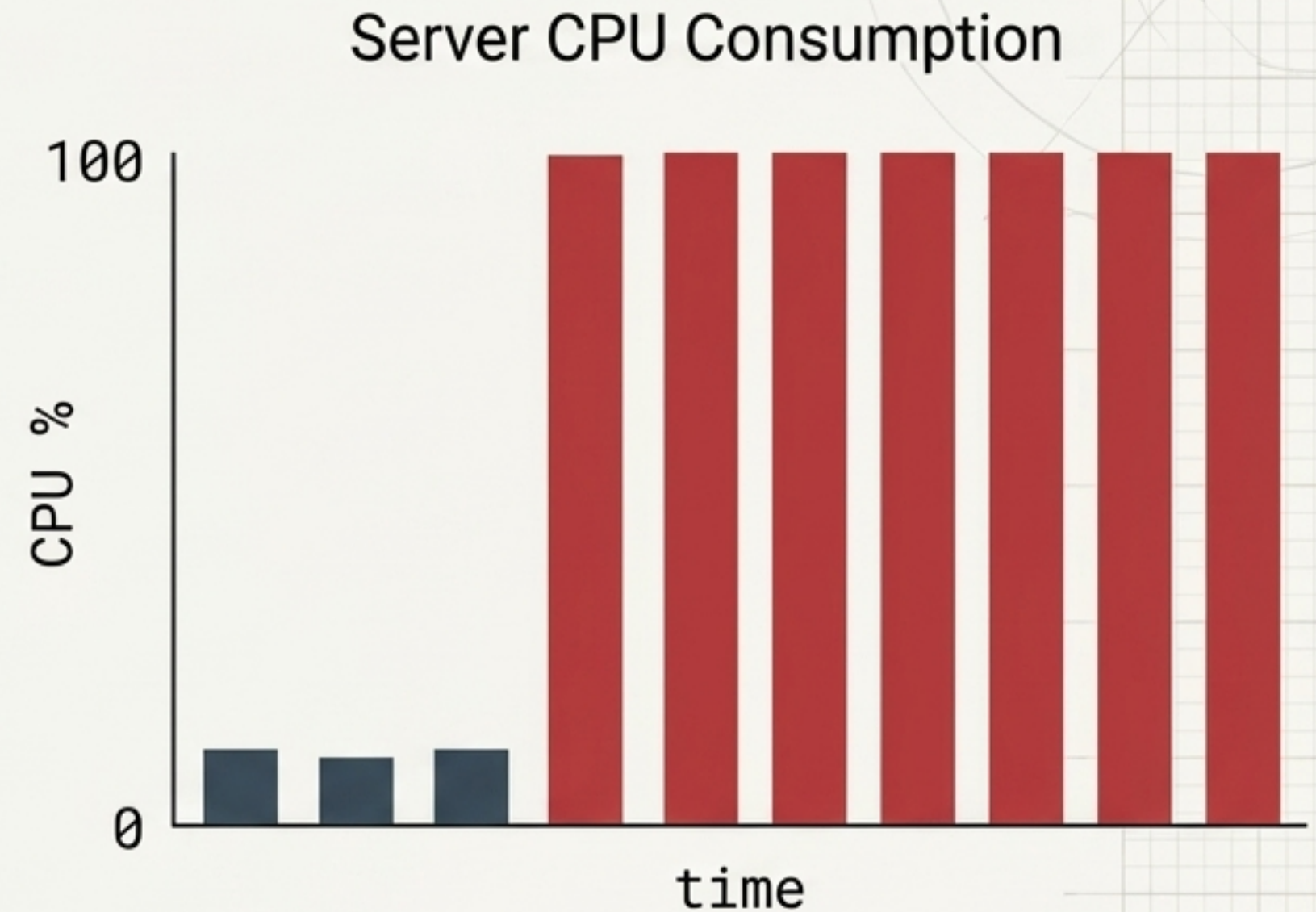
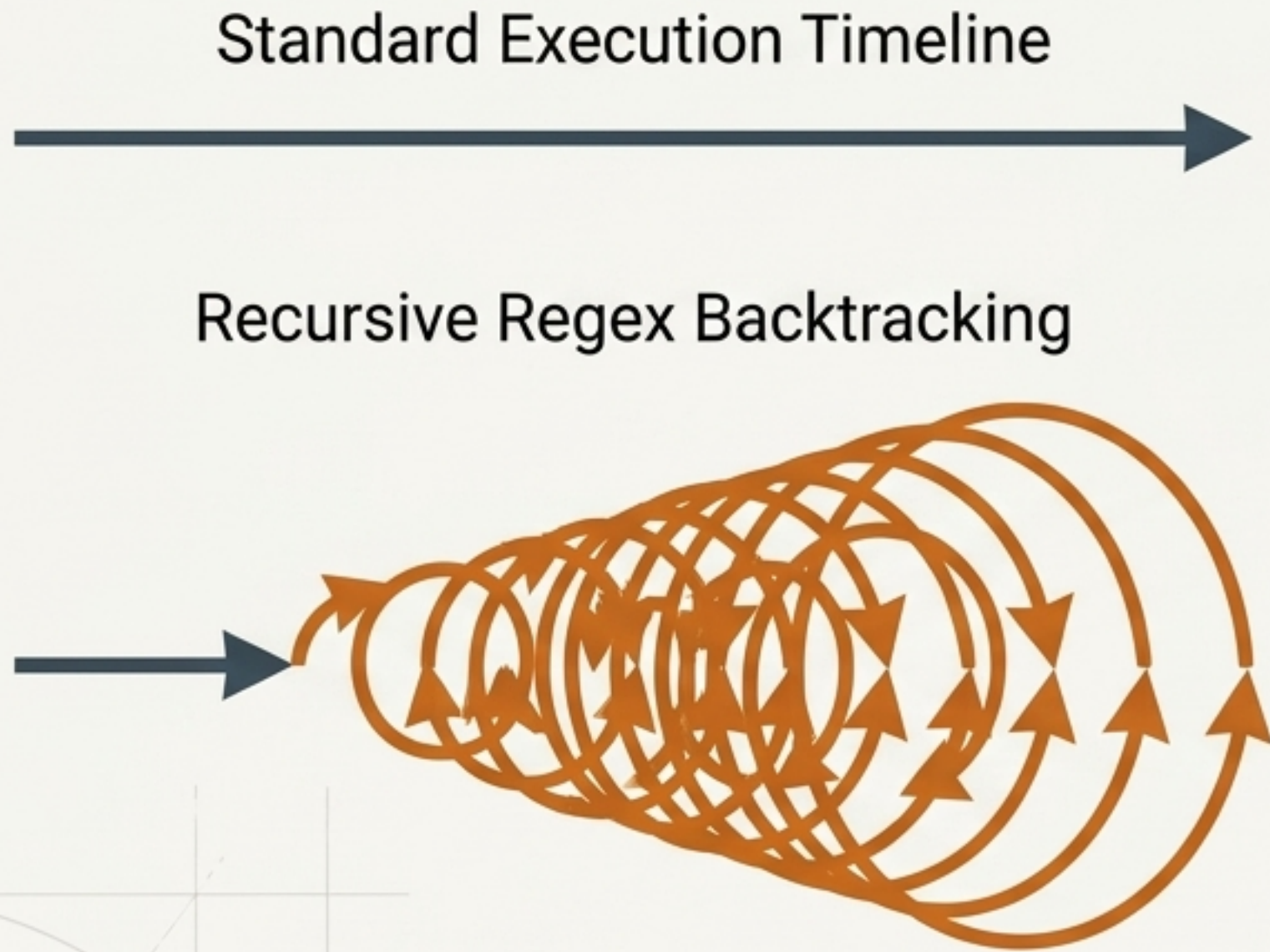


A single input vector dictates two critical failure modes based on payload construction.

Dual-Threat Diagnostic Matrix

	Remote Code Execution (RCE)	Regular Expression DoS (ReDoS)
Primary Mechanism	Bypasses faulty regex to inject arbitrary PHP into eval().	Intentionally submits highly complex input to force recursive regex evaluation loops.
Technical Identifier	CWE-94 (Code Injection)	CWE-1333 (Regex Complexity)
Ultimate Impact	Full server compromise, backdoor installation, data exfiltration.	Resource exhaustion, application freeze, service unavailability.

The Excessive Backtracking Feedback Loop



Specially crafted input forces the regex engine to evaluate an exponentially increasing number of paths, locking the processor and causing an immediate Denial of Service.

Threat Profile and MITRE Mapping

CIA Impact Status

Confidentiality		100%	HIGH
Integrity		100%	HIGH
Availability		100%	HIGH

ATT&CK Vectors

T1190: Exploit Public-Facing Application
T1059: Command and Scripting Interpreter
T1505: Server Software Component
T1499: Endpoint Denial of Service

Attacker Objectives

- Upload Web Shells
- Steal Credentials
- Modify Wiki Content
- Install Malware
- Delete Files

Telemetry and Indicators of Compromise

Server-Side Anomalies



Unexplained, sustained High CPU Events (indicating **ReDoS**).



Unexpected PHP Execution errors.



Suspicious or highly obfuscated Formula Entries in logs.

Perimeter & Stack Defense



Web Application Firewall (WAF) **anomaly alerts**.



IDS/IPS **payload detection**.



File Integrity Monitoring (FIM) **triggering** on **unexpected new files** or **unknown administrative activity**.

Remediation and Defensive Posture



**Target Safe State:
YesWiki 4.6.6+**

**Upgrade immediately to patch
CalcField.php and remove
unsafe eval() implementations.**

Mitigation Sequence for Unpatched Systems

- 1** Restrict formula execution privileges.
- 2** Deploy rigorous WAF rules targeting PHP injection patterns.
- 3** Perform continuous log monitoring for CPU spikes and unexpected backend activity.
- 4** Execute internal code review on custom Wiki plugins interacting with formulas.